

TD : Audit de sécurité d'une application web avec Kali Linux

Master 1. Séminaire Sécurité Opérationnelle

Mettre en œuvre une méthodologie d'audit de vulnérabilités web à l'aide d'outils Kali Linux, identifier et exploiter des vulnérabilités du Top 10 OWASP, documenter une preuve d'exploitation et proposer des mesures de remédiation adaptées.

Environnement de travail : une machine attaquante sous Kali Linux et une machine cible hébergeant une application web volontairement vulnérable, connectées sur un même réseau isolé, sans accès à Internet. Vérifier la connectivité entre les deux machines et relever l'adresse IP de la cible avant de commencer.

Consigne éthique : toute technique mise en œuvre dans ce TD est strictement réservée à cet environnement de laboratoire et ne doit en aucun cas être reproduite sur un système sans autorisation explicite.

Pour chaque exercice, l'étudiant identifie lui-même la méthode d'exploitation à partir de ses recherches et de ses connaissances du cours ; aucune procédure détaillée n'est fournie, il s'agit d'une mise en situation d'audit réel.

N.B. Faire une vidéo qui démontre toutes les étapes réalisées.

Exercice 1. Reconnaissance et cartographie

Réaliser une phase de reconnaissance de l'application cible afin d'identifier sa structure et ses points d'entrée.

- Identifier les technologies utilisées (serveur, langage, base de données)
- Cartographier les pages et fonctionnalités accessibles
- Repérer les paramètres susceptibles d'être manipulés par un attaquant
- Consigner les informations collectées dans un tableau de synthèse

Exercice 2. Injection vers la base de données

Analyser un formulaire ou un paramètre suspecté de transmettre des données non filtrées vers la base de données.

- Déterminer si le paramètre étudié est vulnérable
- Construire une preuve de concept démontrant l'impact sur la confidentialité des données
- Relever la requête ou l'outil utilisé pour parvenir au résultat

Exercice 3. Exécution de commandes système

Analyser une fonctionnalité de l'application interagissant avec le système d'exploitation du serveur.

- Déterminer si des commandes système arbitraires peuvent être exécutées
- Construire une preuve de concept démontrant l'impact sur l'intégrité du serveur
- Identifier les conditions qui permettent ou empêchent l'exploitation

Exercice 4. Injection de code côté client

Analyser les zones de saisie utilisateurs affichés ensuite dans les pages de l'application.

- Déterminer si un contenu actif peut être injecté et restitué au navigateur
- Distinguer un impact immédiat d'un impact persistant pour les autres utilisateurs
- Évaluer les conséquences possibles sur la sécurité des sessions utilisateurs

Exercice 5. Dépôt de fichiers

Analyser une fonctionnalité permettant le téléversement de fichiers vers le serveur.

- Déterminer si les contrôles mis en place peuvent être contournés
- Construire une preuve de concept démontrant une prise de contrôle partielle du serveur
- Identifier les mesures qui auraient empêché cette exploitation